

CLOUD-4 — #520: the floor job stops trusting a mutable tag

Batch of 2026-08-26 · merge order 4 of 5 (independent — lands any time; numbered here for the queue's sake).

```
task_id: gv-520-cloud-4
issue: 520
branch: cloud/520-floor-pin
base: main          # 682f3061 or later
adr_number: 0087    # ASSIGNED — this is a security-boundary decision; it gets an ADR.
sign_commits_as:
  name: Claude_Max
  email: 262510778+tom2025b@users.noreply.github.com
  # per-commit, ALWAYS: git -c user.name=Claude_Max -c
  user.email=262510778+tom2025b@users.noreply.github.com commit ...
allowed_paths:
  - .github/workflows/ci.yml
  - docs/adr/
forbidden_paths:
  - crates/**          # this task is CI + docs only
  - ci/browser/**
deliverables:
  - branch pushed, PR opened with "Closes #520"
  - ADR 0087 + index entry
```

Environment truths

- You cannot run GitHub Actions locally; the PR's own CI run IS the verification vehicle. Design the change so its failure mode is legible in the Actions log (a wrong-commit refusal must NAME expected vs got).
- **You CAN dry-run the verification logic in your container:** clone `github.com/git/git`, resolve the tag, compare against your mapping — do that and put the transcript in the PR body, so the reviewer sees the mechanism work before Actions does.
- Browser leg irrelevant here, but state "ci/browser/run.sh unrun — CI-only change" in the PR body anyway so the standing checklist reads clean.

The defect (codex cloud, \$M3 — REASONED; the local review found no defect in the same job: reconcile, don't assume)

`.github/workflows/ci.yml:186-226` (re-verify the range on your checkout — it may have drifted) clones `github.com/git/git` at tag `v${floor}.0` on cache miss, builds, installs, executes — inside a **required** merge job. It verifies the PRINTED VERSION but pins no commit and checks no checksum. A moved tag or compromised retrieval path yields a binary that prints `git version 2.32.0`, passes, and is cached under the trusted key. The cache key also omits arch/toolchain identity.

Your first job is the reconciliation the issue asks for: read the job as it stands and state plainly whether the reasoned attack path is real on the current YAML (tag→build→cache→required-job). If any link is already closed, the ADR says which and the fix shrinks accordingly.

The fix direction (from the issue, refined)

1. **A reviewed version→commit mapping, checked at build time.** The doc heading stays the source of the VERSION; CI separately proves it got the reviewed SOURCE for that version: after checkout, `git rev-parse HEAD^{}` (peel the tag) must equal the pinned commit for that version, or the job fails naming both hashes. The mapping lives in the workflow (or a small tracked file beside it) with a comment saying how to update it when the floor moves — the update procedure is part of the boundary, write it.
2. **Fix the cache key:** include the pinned commit AND the runner arch/toolchain identity, so a poisoned or mismatched artifact cannot be served under the trusted key after the pin lands.
3. Keep proportion: single-user repo, not urgent — the ADR should say what this defends against and what it deliberately does not (no reproducible -build ambitions, no signature verification of upstream — a pinned commit hash is the right-sized boundary).

Acceptance

1. Floor job refuses a tag that does not peel to the pinned commit, with a message naming expected and got.
2. Cache key carries commit + arch/toolchain identity.
3. Local dry-run transcript of the verification logic in the PR body (correct tag passes; a deliberately wrong pin refuses — that pair is this task's mutation proof, since the mechanism lives in YAML).
4. ADR 0087: the boundary, the reconciliation verdict, the update procedure, the non-goals.
5. PR body: the reconciliation statement, the dry-run pair, the browser-leg line, your session tag. CI on the PR itself must pass with the new check live (cache-miss path exercised or explained).

Written by fable · 2026-08-26 · job location re-check is YOUR first step; the YAML may have moved since the review.